

Halden Distribution Ltd. — Monitoring and log collection policy

Version: 1.0 (draft for approval) · **Owner:** IT · **Approver:** Managing Director (*unsigned*) **Date:** 2026-10-02
· **Applies to:** all systems and all staff · **Related:** `p07-ir-plan.md`

1. Why this policy exists

Halden now collects and analyses security logs centrally. That is a good thing for the business — it is how we catch an attack before it becomes a ransom demand — but it is also a change in how the company sees its own systems, and it has privacy implications that deserve to be written down and agreed, not assumed.

****The principle in one sentence: we monitor systems for security and availability, not people for performance.**** This policy makes that principle concrete and auditable.

2. What is collected and why

Source	What is collected	Why (the use case)
Windows servers and workstations	Security events (logons, group and account changes), Sysmon (process, network, file and registry activity), PowerShell script-block logging, Defender events	Detect credential abuse, persistence and ransomware preparation
Domain controllers	Directory and Kerberos events	Detect privileged group changes, DCSync, Kerberos abuse
Linux servers	Login, sudo and audit logs	Detect SSH abuse and privilege misuse
Firewalls (FW01/FW02)	Connection and VPN logs	Detect perimeter and remote-access anomalies
Backup and availability systems	Backup job outcomes, service availability	Catch a failed backup before a restore is needed

Each source exists because a specific detection or runbook needs it. We do not collect "everything just in case".

3. Retention

Data	Retention (planned)	Rationale
Hot alerts and events in the SIEM	90 days	Covers the "found out weeks later" case; the lab is not sized for longer
Raw evidence for a specific incident	For the life of the incident + review	Needed for the report and any claim

Data	Retention (planned)	Rationale
Backups of the SIEM configuration and rules	In the repository (no data, only config)	Rebuildability

After the retention period, data is deleted. Where data must be kept longer for a specific legal reason, that is recorded with the reason.

4. Privacy commitments

1. **Purpose limitation.** Logs are used for security, availability and incident response. They are **not** used for productivity monitoring, not used to assess individual performance, and not used for any purpose unrelated to running and protecting the business.

1. **Least collection.** We collect what a documented detection needs, not more.

2. **Access control.** Access to the SIEM is limited to IT and is itself logged. Looking at a real person's activity requires a stated reason, which is recorded in the case notes.

1. **Transparency.** Staff are told what is collected and why (this document), and it is not a secret.

1. **Retention is finite.** Data does not live forever (see §3).

2. **Personal content is not the target.** We log system and service activity (logons, processes, service changes, availability), not the contents of documents or messages.

1. **Proportionality in an investigation.** During an incident, access to a person's activity is limited to what the investigation genuinely needs, and the Incident Lead approves it.

5. Who can see what

Role	Access	Notes
IT analyst	Alerts and logs needed for triage	Access logged; reason recorded for person-specific views
IT Manager (Incident Lead)	Full SIEM	Approves person-specific investigations
Managing Director	Incident reports and summaries	Not raw logs, unless required for a SEV1 decision
Staff	Their own system's availability status (status page)	Public within the company

6. Legal and regulatory considerations

- Log data can include personal data (usernames, IP addresses, session times), so it is handled with the same care as any personal data.
- Pakistan:** PECA 2016 applies to cyber offences; check the status of the Personal Data Protection

Bill for the current personal-data rules, and any sector regulator (e.g. SBP for banks).

- **If we serve EU customers:** GDPR applies, including the 72-hour breach-notification rule.
- Any subject-access or employee request relating to monitoring data goes to the Managing Director **and** legal counsel before any data is released.

7. Review

- Reviewed annually, and after any incident that raised a privacy question.
- The tabletop exercise includes a privacy inject (a staff member asks "are you watching me?") so the answer is rehearsed.

8. What staff should know (the short version)

Halden now watches its **systems** for security and availability, the way a building has smoke alarms. It records things like logons, system changes and whether services are up. It is **not** used to check how hard you are working or what is inside your documents. If you have a question about this, ask IT or the Managing Director — the answer is not a secret.

9. Approval

Role	Name	Signature	Date
Managing Director			
IT Manager			

Halden Distribution Ltd. is a fictional company for a home-lab portfolio project. This policy is real written work; the company, the approvers and their signatures are simulated, and the approval block is deliberately unsigned.